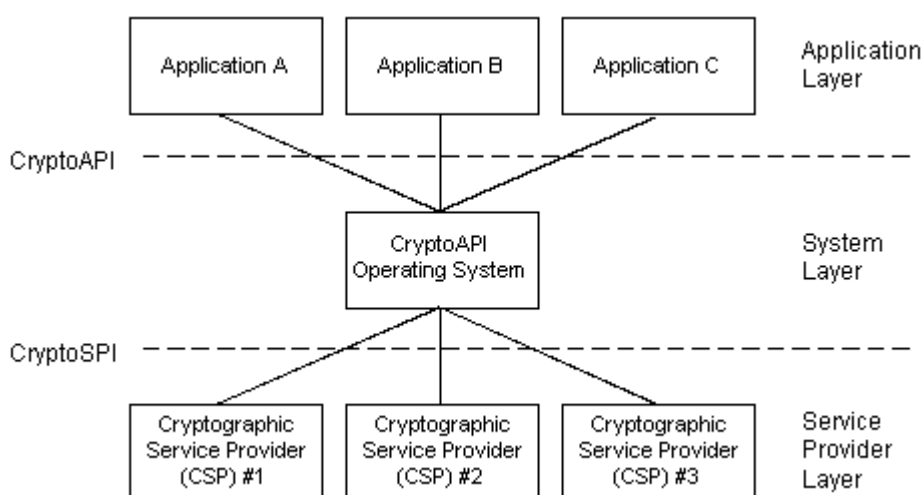


บทที่ 5

คริปโตเอพีไอ

(Cryptographic Application Programming Interface)

ในการการพัฒนาตัวโปรแกรมคณะผู้จัดทำได้ใช้เอพีไอ (API – Application Programming Interface) ของไมโครซอฟท์วินโดวส์ที่ชื่อว่าคริปโตเอพีไอ ซึ่งเป็นเอพีไอตัวหนึ่งที่มีความสามารถในการทำงานในด้าน การเข้ารหัส ถอดรหัสและสามารถสร้างลายมือชื่อดิจิตอลได้ โดยเอพีไอดังนี้ จะทำการติดต่อกับส่วนที่เรียกว่า ซีเอสพี (CSP – Cryptographic Service Provider), ระบบปฏิบัติการรวมถึงที่เก็บเอกสารสิทธิ์ (Certificate Store) ภายในเครื่องคอมพิวเตอร์ โครงสร้างความสัมพันธ์ระหว่างคริปโตเอพีไอ และส่วนต่าง ๆ นั้นมีลักษณะดังรูป



รูปที่ 5.1 แสดงโครงสร้างความสัมพันธ์ของคริปโตเอพีไอและซีเอสพี

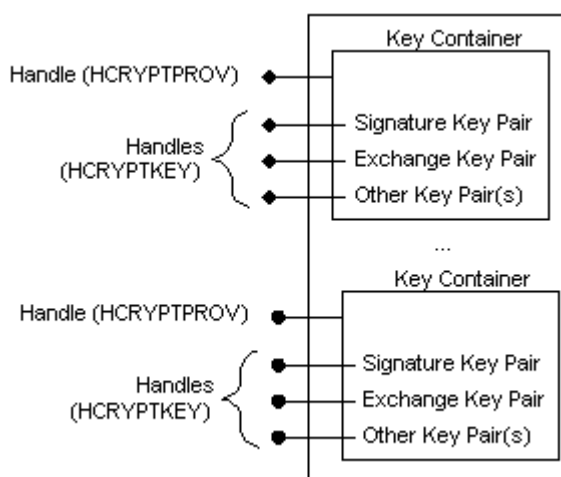
ภายในซีเอสพีจะมีวัตถุต่าง ๆ ที่ใช้ในการทำงาน วัตถุที่อยู่ในซีเอสพี ได้แก่ คีย์คอนเทนเนอร์ (Key Container), วัตถุแฮช (Hash Object), วัตถุเซสชันคีย์ (Session Key Object) และ วัตถุคีย์ส่วนตัว – คีย์สาธารณะ (Private – Public Key Object) ตัวโปรแกรมจะทำการติดต่อกับวัตถุต่าง ๆ ภายในซีเอสพีโดยผ่านแฮนเดิล (Handle) ที่ผูกกับวัตถุที่ต้องการติดต่อด้วย

5.1 โครงสร้างของซีเอสพี

5.1.1 คีย์คอนเทนเนอร์ (Key Container)

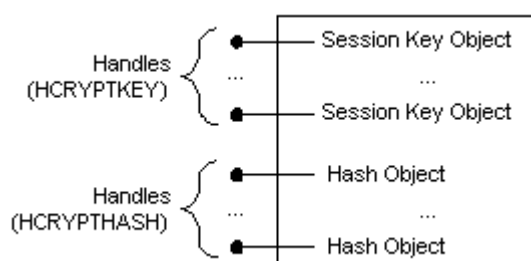
แต่ละซีเอสพีจะเก็บคู่คีย์ต่าง ๆ ภายในภายในคีย์คอนเทนเนอร์ ซึ่งเปรียบเสมือนฐานข้อมูลที่ใช้เก็บคู่คีย์ต่าง ๆ โดยคีย์คอนเทนเนอร์จะมีชื่อเรียกเฉพาะเพื่อใช้ในการระบุและจัดการกับคู่คีย์ภายในคีย์คอนเทนเนอร์นั้น ๆ ได้ แต่ละซีเอสพีนั้นจะเป็นผู้จัดการเองว่าให้คีย์คอนเทนเนอร์นั้นไปเก็บไว้ที่ใด อาจเก็บไว้ในฮาร์ดแวร์เฉพาะ (Tamper - resistant hardware), เก็บไว้ในรีจิสทรี (Registry) หรือเก็บไว้ในไฟล์ซิสเต็ม เป็นต้น การเก็บวัตถุต่าง ๆ ภายในซีเอสพี ออกเป็น 2 ประเภทดังนี้

1. เก็บไว้ในหน่วยความจำถาวร (Persistent Data Objects) ซีเอสพีจะเก็บคีย์ส่วนตัวและคีย์สาธารณะไว้ในหน่วยความจำถาวรในรูปแบบที่ทำการเข้ารหัสไว้



รูปที่ 5.2 แสดงโครงสร้างที่เก็บข้อมูลแบบถาวรของคีย์คอนเทนเนอร์

2. เก็บไว้ในหน่วยความจำชั่วคราว ซีเอสพีจะทำการเก็บวัตถุเซชันคีย์ และ วัตถุแฮชในหน่วยความจำชั่วคราวเมื่อมีการเรียกใช้งานวัตถุนั้น ๆ ซึ่งวัตถุต่าง ๆ เหล่านี้จะถูกทำลายเมื่อมีการคืนหน่วยความจำที่เก็บแสดนเดลของคีย์คอนเทนเนอร์และซีเอสพี



รูปที่ 5.3 แสดงโครงสร้างที่เก็บข้อมูลแบบชั่วคราวของคีย์คอนเทนเนอร์

5.1.2 วัตถุคีย์เซสชัน (Session Key Object)

วัตถุคีย์ที่ใช้ในการเข้ารหัส/ถอดรหัสแบบสมมาตร โดยทั่วไปคีย์นี้จะมีขนาด 40 ถึง 2,000 บิต

5.1.3 วัตถุคีย์ส่วนตัวและคีย์สาธารณะ (Private and Public Key Object)

วัตถุคีย์ที่ใช้ในการเข้ารหัส/ถอดรหัสแบบไม่สมมาตร โดยทั่วไปซีเอสพีจะแบ่งคีย์ประเภทนี้ออกเป็น 2 ประเภทคือ คีย์ลายมือชื่อ (Signature Key Pair) และ คีย์แลกเปลี่ยน (Exchange Key Pair)

5.1.4 คีย์ลายมือชื่อ (Signature Key Pair)

เป็นคู่คีย์ที่มีไว้ในการพิสูจน์ตน จะถูกใช้ในการลงนามลายมือชื่อดิจิตอล การเข้ารหัสแบบไม่สมมาตร

5.1.5 คีย์แลกเปลี่ยน (Exchange Key Pair)

เป็นคู่คีย์ที่มีไว้สำหรับการทำการเข้ารหัส/ถอดรหัสเซสชันคีย์ มีไว้เพื่อประโยชน์ในการกระจายคีย์

5.1.6 วัตถุแฮช (Hash Object)

วัตถุที่เก็บเมสแซจไดเจสต์ของข้อมูลที่ผ่านมาแฮชฟังก์ชัน

ในการพัฒนาโปรแกรมให้มีความสามารถอย่างเต็มที่การเขียนโปรแกรมให้สามารถที่จะเรียกใช้คริปโตเอพีไอให้ถูกต้องได้นั้นจำเป็นที่จะต้องรู้ถึงคำสั่งต่าง ๆ ในการเรียกเอพีไอให้เป็นลำดับที่ถูกต้อง คำสั่งต่าง ๆ จะถูกกำหนดไว้ในไฟล์ที่ชื่อ Wincrypt.h ซึ่งผู้ที่พัฒนาโปรแกรมจำเป็นต้องรู้ถึงคำสั่งพื้นฐานในการใช้งานของเอพีไอ แต่ก่อนอื่นคณะผู้จัดทำจึงขอทำการอธิบายคำศัพท์ต่าง ๆ ที่สำคัญในการเรียกคริปโตเอพีไอก่อนดังนี้

5.2 ชนิดของซีเอสพี

เป็นชนิดของซีเอสพีนั้นมีได้หลายชนิดและแต่ละชนิดจะมีรูปแบบของข้อมูล (Data Format) ที่ไม่เหมือนกันหรืออาจเป็นฟังก์ชันการทำงานใช้อัลกอริทึมในการทำงานไม่เหมือนกัน ในชนิดของโพรไวเดอร์หนึ่ง ๆ นั้น จะมีซีเอสพีหลายตัวที่เป็นแบบเดียวกัน เราสามารถแบ่งชนิดของโพรไวเดอร์ได้ดังนี้

1. PROV_DSS Provider Type เป็นชนิดของโพรไวเดอร์ที่สามารถสร้างลายมือชื่อดิจิตอลและทำการหาค่าแฮชได้ ซึ่งภายในจะประกอบไปด้วย อัลกอริทึมการลงลายมือชื่อ การทำแฮชซึ่งแบบ MD5 และการทำแฮชซึ่งแบบ SHA – 1

2. PROV_DSS_DH Provider Type เป็นชนิดของโพรไวเดอร์ที่มีความสามารถในการทำคีย์แลกเปลี่ยนคีย์ลายมือชื่อและการทำแฮชซึ่งจะคล้ายกับ PROV_DSS

3. PROV_FROTEZZA Provider Type เป็นโพรไวเดอร์ที่มีความสามารถในการทำคีย์แลกเปลี่ยนคีย์ลายมือชื่อ การเข้ารหัสและการทำแฮชซึ่งในชนิดนี้อัลกอริทึมต่าง ๆ จะถูกกำหนดโดยสถาบัน National Institute of Standards and Technology (NIST)

4. PROV_MS_EXCHANGE Provider Type จะใช้สำหรับโปรแกรมไมโครซอฟท์เอ็กเชนจ์ (Microsoft Exchange) หรือว่าโปรแกรม (Application) ที่ทำหน้าที่คล้ายไมโครซอฟท์เมล (Microsoft Mail) ซึ่งชนิดโพรไวเดอร์ชนิดนี้จะสามารถทำการแลกเปลี่ยนคีย์ได้ ทำการลงนามลายมือชื่อดิจิตอลได้ เข้ารหัสข้อมูล และทำการแฮชซึ่ง

5. PROV_RSA_FULL Provider Type เป็นโพรไวเดอร์ที่ทั้งไมโครซอฟท์ (Microsoft) และอาร์เอสเอเคด้าซีเคียวริตี (RSA Data Security) ช่วยกันจัดทำขึ้นมาถือเป็นชนิดโพรไวเดอร์ที่ทำหน้าที่ได้หลากหลาย เช่น การทำแลกเปลี่ยนคีย์ การลงนามลายมือชื่อดิจิตอล การเข้ารหัสข้อมูล และการทำแฮชซึ่ง โดยการทำงานต่าง ๆ ที่เกี่ยวข้องกับการเข้ารหัส/ถอดรหัสนั้นจะใช้ฟังก์ชันการทำงานของอาร์เอสเอเป็นหลัก

6. PROV_RSA_SIG Provider Type เป็นชนิดโพรไวเดอร์อีกชนิดหนึ่งที่ถูกจัดทำโดยไมโครซอฟท์และอาร์เอสเอเคด้าซีเคียวริตี ซึ่งชนิดโพรไวเดอร์ชนิดนี้เป็นส่วนที่แตกออกมาจาก PROV_RSA_FULL แต่ว่าในชนิดนี้จะสามารถทำได้แค่การลงนามลายมือชื่อดิจิตอลและการทำแฮชซึ่งเท่านั้น

7. PROV_SSL Provider Type เป็นชนิดโพรไวเดอร์ที่มีความสามารถในการทำตามมาตรฐานเอสเอสแอล (SSL – Secure Sockets Layer) ซึ่งชนิดของโพรไวเดอร์ชนิดนี้สามารถที่จะทำคีย์แลกเปลี่ยน คีย์ลายมือชื่อ คีย์การเข้ารหัสข้อมูลและการทำแฮชซึ่ง

5.3 ชื่อของซีเอสพี

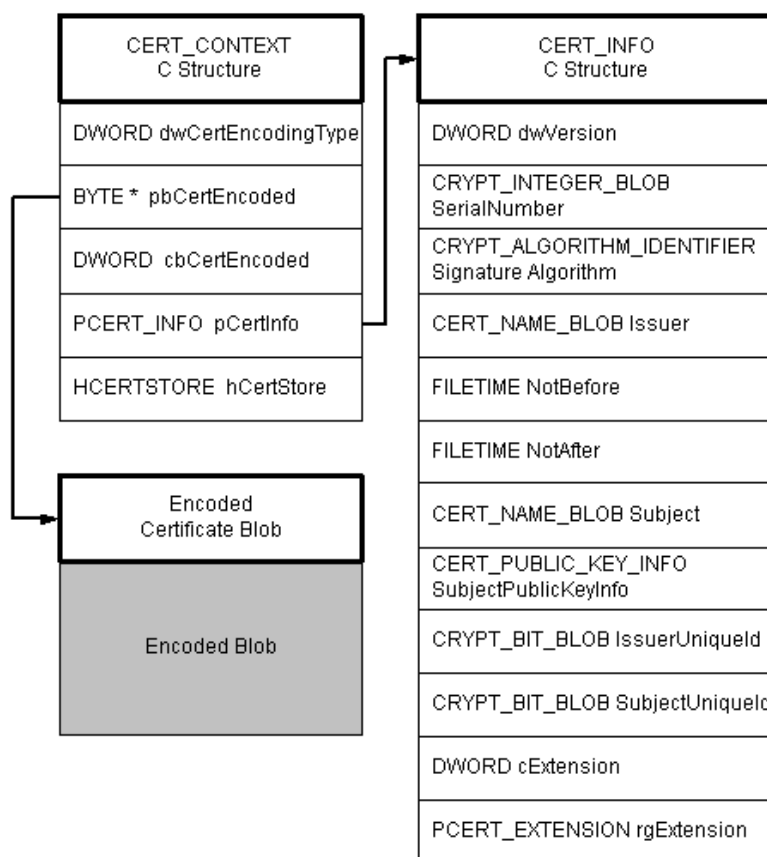
เป็นชื่อที่ใช้บ่งบอกว่าเป็นซีเอสพีตัวใด มีตัวอย่างรายชื่อของไมโครซอฟท์ดังต่อไปนี้

Defined Name	Value
MS_DEF_PROV	"Microsoft Base Cryptographic Provider v1.0"
MS_ENHANCED_PROV	"Microsoft Enhanced Cryptographic Provider "
MS_DEF_RSA_SIG_PROV	"Microsoft RSA Signature Cryptographic Provider"
MS_DEF_RSA_SCHANNEL_PROV	"Microsoft RSA Schannel Cryptographic Provider"
MS_DEF_DSS_PROV	"Microsoft Base DSS Cryptographic Provider"
MS_DEF_DSS_DH_PROV	"Microsoft Base DSS and Diffie-Hellman Cryptographic Provider"
MS_ENH_DSS_DH_PROV	"Microsoft Enhanced DSS and Diffie-Hellman Cryptographic Provider"
MS_DEF_DH_SCHANNEL_PROV	"Microsoft DH Schannel Cryptographic Provider"

ตารางที่ 5.1 ตารางแสดงชื่อของซีเอสพี

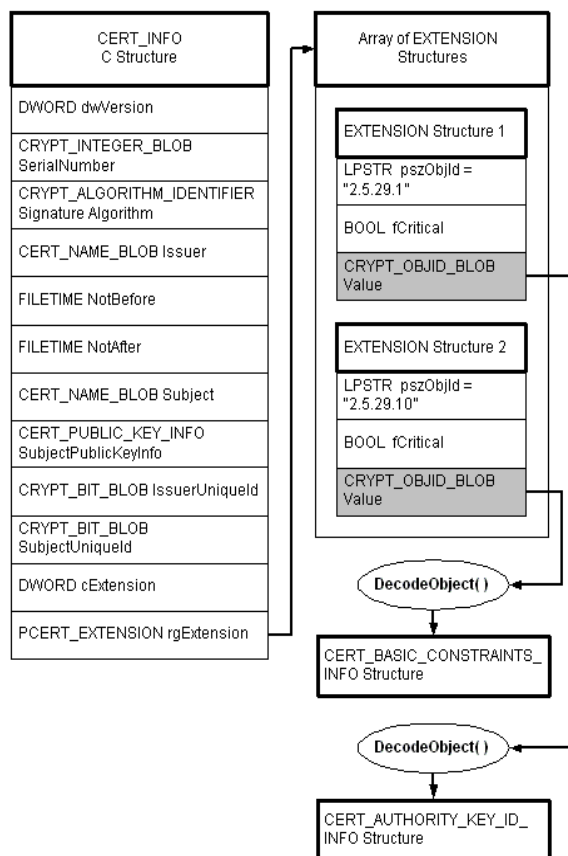
5.4 โครงสร้าง CERT_CONTEXT และ CERT_INFO

CERT_CONTEXT โครงสร้างโดยทั่วไปของ CERT_CONTEXT คือ เป็นที่เก็บเอกสารสิทธิ์ (CERT_INFO ซึ่งจะกล่าวถึงต่อไป) ความยาวของเอกสารสิทธิ์, รูปแบบการเข้ารหัสข้อมูลของเอกสารสิทธิ์



รูปที่ 5.4 โครงสร้างของ CERT_CONTEXT

CERT_INFO เป็นส่วนที่เก็บข้อมูลหลักของเอกสารสิทธิ์ ซึ่งจะมีรายละเอียดข้อมูลเกี่ยวกับเอกสารสิทธิ์นี้ เช่น หมายเลขของเอกสารสิทธิ์ (Serial Number), ชื่อเจ้าของเอกสารสิทธิ์ (Subject name), องค์กรที่ปล่อยเอกสารสิทธิ์ (Issuer name), ระดับของความปลอดภัยของคู่มือ, วันที่ออกเอกสารสิทธิ์ (Issue Date), วันที่เอกสารสิทธิ์หมดอายุหรือไม่ถูกรับรอง (Revocation Date) เป็นต้น โดยส่วนที่เก็บข้อมูลจะมีทั้งที่ทำการเข้ารหัสและไม่ได้เข้ารหัสของเอกสารสิทธิ์



รูปที่ 5.5 โครงสร้างของ *CERT_INFO*

การที่เราจะแสดงข้อมูลในฟิลด์ที่เข้ารหัสไว้ให้ผู้ดูและตรวจสอบค่าต่าง ๆ ต้องทำการถอดรหัสฟิลด์นั้น ๆ ก่อน วิธีการที่คณะผู้จัดทำใช้ในการถอดรหัสนั้นมีสองวิธีคือ

1. ใช้ฟังก์ชัน CryptDecodeObject ในการถอดรหัสฟิลด์ใด ๆ ที่ทำการเข้ารหัสไว้
2. ใช้ฟังก์ชัน CertNameToStr ในการถอดรหัสฟิลด์ที่เก็บชื่อเจ้าของเอกสารสิทธิ์และชื่อขององค์กรที่ออกเอกสารสิทธิ์

5.5 การติดต่อและการใช้รีปโตเอพีในการติดต่อกับเอกสารสิทธิ์

5.5.1 คำศัพท์ที่เกี่ยวข้อง

CRL – Certificate Revocation List คือ รายชื่อของเอกสารสิทธิ์ที่ถูกนำกลับมาใช้ใหม่ เช่น ในกรณีที่เอกสารสิทธิ์นั้น เจ้าของอาจจะไม่ต้องการใช้อีกต่อไปก็จะสามารถนำกลับไปให้ผู้อื่นใช้ต่อไปได้

CTL – Certificate Trust List คือ รายชื่อของเอกสารสิทธิ์ที่สามารถเชื่อถือได้
คำสั่งต่าง ๆ ที่ใช้ในการติดต่อกับเอกสารสิทธิ์สามารถแบ่งคำสั่งต่าง ๆ ที่สำคัญออกเป็นกลุ่มได้ดังนี้

5.5.2 ฟังก์ชันติดต่อกับที่เก็บเอกสารสิทธิ์ (Certificate Store Functions)

มีฟังก์ชันดังต่อไปนี้

1. CertOpenStore ใช้เพื่อทำการเปิดที่เก็บเอกสารสิทธิ์ (Certificate Store) โดยจะต้องกำหนดชนิดผู้ให้บริการที่เก็บเอกสารสิทธิ์ด้วย
2. CertRegisterSystemStore ใช้เพื่อทำการลงทะเบียน (Register) ที่เก็บเอกสารสิทธิ์โดยเราสามารถระบุได้ว่าจะให้เก็บไว้ตรงส่วนใด
3. CertSetStoreProperty ใช้เพื่อทำการตั้งค่าต่าง ๆ ให้กับที่เก็บเอกสารสิทธิ์

5.5.3 ฟังก์ชันติดต่อกับเอกสารสิทธิ์ (Certificate Functions)

มีฟังก์ชันดังต่อไปนี้

1. CertAddCertificateContextToStore ใช้เพื่อเพิ่มเอกสารสิทธิ์อันใหม่เข้าไปในที่เก็บเอกสารสิทธิ์
2. CertFindCertificateInStore ใช้สำหรับการหาเอกสารสิทธิ์ที่อยู่ในที่เก็บเอกสารสิทธิ์ โดยในการหาครั้งแรกนั้น จะได้เอกสารสิทธิ์ตัวแรกออกมา และในครั้งต่อไปจะได้ตัวถัดไปเรื่อย ๆ ออกมา
3. CertDuplicateCertificateContext ใช้เมื่อต้องการที่จะทำสำเนาของเอกสารสิทธิ์ไว้

5.5.4 ฟังก์ชันติดต่อกับที่เก็บรายชื่อของเอกสารสิทธิ์ที่ถูกนำกลับมาใช้ใหม่ (Certificate Revocation List Functions)

มีฟังก์ชันดังต่อไปนี้

1. CertAddCRLContextToStore เป็นการเพิ่ม CRL Context ลงไปที่เก็บเอกสารสิทธิ์
2. CertAddCRLLinkToStore ใช้เมื่อต้องการเพิ่มลิงค์ (Link) ให้กับ CRL ในที่เก็บเอกสารสิทธิ์อันหนึ่งเพื่อชี้ไปยัง CRL อื่นในที่เก็บเอกสารสิทธิ์อื่น
3. CertDuplicateCRLContext เป็นฟังก์ชันที่ถูกเรียกใช้เมื่อต้องการทำสำเนาของ CRL
4. CertFindCRLInStore ใช้เมื่อต้องการหา CRL ที่มีอยู่ในที่เก็บเอกสารสิทธิ์

5.5.5 ฟังก์ชันติดต่อกับที่เก็บรายชื่อของเอกสารสิทธิ์ที่สามารถเชื่อถือได้ (Certificate Trust List Functions)

มีฟังก์ชันดังต่อไปนี้

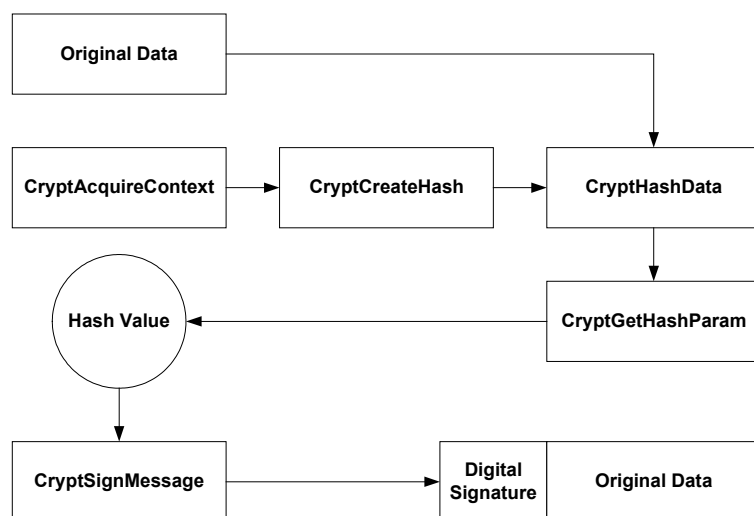
1. CertAddCTLContextToStore ใช้เมื่อต้องการเพิ่ม CTL Context ลงในที่เก็บเอกสารสิทธิ์
2. CertDuplicateCTLContext ใช้เมื่อต้องการจะทำสำเนา CTL Context

3. CertFindCTLInStore ใช้เมื่อต้องการหา CTL ที่อยู่ภายในที่เก็บเอกสารสิทธิ์

5.6 ขั้นตอนการสร้างลายมือชื่อดิจิตอล

การสร้างลายมือชื่อดิจิตอลมีขั้นตอนดังนี้

1. ขั้นตอนแรกในการติดต่อกับซีเอสพีนั้นจะเริ่มจากการที่โปรแกรม เรียกใช้ฟังก์ชัน CryptAcquireContext เพื่อที่จะใช้จัดการกับซีเอสพีใด ๆ โดยเมื่อเรียกใช้คำสั่งนี้แล้วจะเป็นการบอกถึงชนิดของซีเอสพี ซีเอสพีที่ต้องการติดต่อ และชื่อของคีย์คอนเทนเนอร์ที่เก็บอยู่ภายในซีเอสพีนั้นด้วย
2. เมื่อเราทำการติดต่อกับซีเอสพีและคีย์คอนเทนเนอร์ได้แล้วเราจะทำการสร้างแฮชเดิมของวัตถุแฮชขึ้นมาก่อน โดยใช้ฟังก์ชัน CryptCreateHash
3. จากนั้นทำการแฮชข้อมูลแล้วเก็บค่าเมสเชจไคเจสต์ไว้ที่ตำแหน่งที่แฮชเดิมที่ชี้วัตถุแฮชอยู่โดยใช้ฟังก์ชัน CryptHashData
4. ขั้นตอนต่อมาคือการนำค่าเมสเชจไคเจสต์ที่ได้มาทำการเข้ารหัสด้วยคีย์ส่วนตัวที่ได้รับการรับรองโดยองค์การพิสูจน์สิทธิ์ ด้วยฟังก์ชัน CryptSignMessage



รูปที่ 5.6 บล็อกไดอะแกรมแสดงการใช้คริปโตเอพีไอในการสร้างลายมือชื่อดิจิตอล

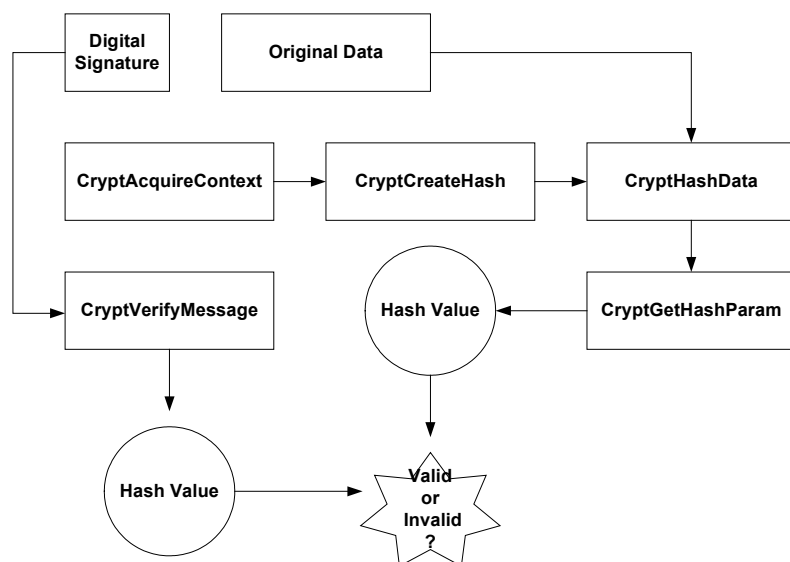
5.7 ขั้นตอนการตรวจสอบลายมือชื่อดิจิตอล

การตรวจสอบลายมือชื่อดิจิตอลมีขั้นตอนดังนี้

1. แยกส่วนที่เป็นข้อมูลต้นฉบับและลายมือชื่อดิจิตอล
2. ในส่วนที่เป็นข้อมูลต้นฉบับ หาค่าเมสเชจไคเจสต์ของข้อมูลต้นฉบับตามลำดับขั้นตอน 1 - 4 เช่นเดียวกับขั้นตอนการสร้างลายมือชื่อดิจิตอล

3. ในส่วนที่เป็นลายมือชื่อดิจิตอลใช้ฟังก์ชัน `CryptVerifyMessage` ในการถอดรหัสลายมือชื่อดิจิตอล ได้เป็นเมสเซจไคเจสต์อีกชุดออกมา

4. ทำการตรวจสอบว่าเมสเซจที่ได้ขั้นตอนที่ 3 และ 4 เหมือนกันหรือไม่ ถ้าเหมือนกันแสดงว่าเอกสารไม่มีการเปลี่ยนแปลง ถ้าไม่เหมือนกันแสดงว่าเอกสารมีการเปลี่ยนแปลง



รูปที่ 5.7 บล็อกไดอะแกรมแสดงการใช้คริปโตเอพีไอในการตรวจสอบลายมือชื่อดิจิตอล